Propuesta de Trabajo Práctico

Seguridad en Aplicaciones Web

Tema

Explotación encadenada de vulnerabilidades en una plataforma web de gestión de pedidos y logística.

Contexto

El trabajo propone el diseño de un laboratorio de seguridad sobre una plataforma web ficticia utilizada por una empresa para gestionar sus operaciones comerciales.

La aplicación permite administrar clientes, pedidos, productos, stock, envíos y facturación. El sistema cuenta con diferentes niveles de acceso, entre ellos usuarios estándar y administradores.

El atacante parte de una cuenta legítima con permisos básicos y busca aprovechar distintas vulnerabilidades de la aplicación para incrementar progresivamente su nivel de acceso hasta comprometer una funcionalidad crítica.

Objetivo

Demostrar cómo la combinación de distintas vulnerabilidades, que individualmente podrían tener un impacto limitado, puede permitir realizar un ataque de mayor alcance sobre información y funcionalidades sensibles del sistema.

El objetivo final de la cadena será **obtener acceso no autorizado y modificar información asociada a pedidos de otros clientes**.

Cadena de ataque propuesta

Paso 1 – Security Misconfiguration (A02)
La aplicación presenta una configuración insegura que permite acceder a documentación o información de la API que no debería estar disponible para usuarios comunes.

Resultado: el atacante obtiene un mapa de endpoints y parámetros relevantes del sistema.

↓

Paso 2 – Broken Access Control / IDOR (A01)
Utilizando la información obtenida, el atacante identifica un endpoint de consulta de pedidos que valida que el usuario esté autenticado, pero no verifica correctamente que el pedido consultado le pertenezca.

Resultado: obtiene información e identificadores pertenecientes a otros clientes.

↓

Paso 3 – Injection / Mishandling of Exceptional Conditions (A05 / A10)
A partir de los recursos descubiertos, el atacante interactúa con una funcionalidad relacionada con los pedidos que presenta validaciones deficientes y permite obtener información adicional sobre la estructura interna de la aplicación.

Resultado: obtiene información que permite identificar una funcionalidad crítica del sistema.

↓

Paso 4 – Broken Function Level Authorization (A01)
El atacante intenta acceder directamente a una funcionalidad destinada a usuarios con mayores privilegios. El endpoint no realiza correctamente la validación del rol y permite ejecutar una operación que debería estar restringida.

Resultado final: el atacante consigue modificar información de pedidos pertenecientes a otros clientes.

Encadenamiento

Acceso a documentación de API → identificación de endpoints → IDOR → obtención de identificadores de otros clientes → descubrimiento de información interna → acceso a función restringida → modificación de pedidos.

Impacto

La explotación encadenada podría comprometer:

- **Confidencialidad:** acceso a información de pedidos y clientes.
- **Integridad:** modificación no autorizada de pedidos.
- **Control de acceso:** ejecución de funcionalidades destinadas a roles superiores.
- **Riesgo operacional:** alteración de información utilizada para la gestión comercial y logística.

Vulnerabilidades OWASP involucradas

- **A01 – Broken Access Control**
- **A02 – Security Misconfiguration**
- **A05 – Injection**
- **A10 – Mishandling of Exceptional Conditions**

El trabajo se desarrollaría como un laboratorio controlado, demostrando conceptualmente y mediante la aplicación ficticia cómo cada vulnerabilidad permite avanzar hacia el siguiente paso de la cadena.